

تعميم

المحترمون

السادة/

السلام عليكم ورحمة الله وبركاته،

الموضوع: دليل المتطلبات الأساسية لمكافحة الاحتيال المالي.

استناداً إلى نظام البنك المركزي السعودي الصادر بالمرسوم الملكي رقم (م/٣٦) وتاريخ ١٤٤٢/٤/١١هـ، وإلى الصلاحيات المنوطة به بموجب الأنظمة ذات العلاقة، وانطلاقاً من دوره الإشرافي والرقابي، وحرصاً منه على تعزيز الممارسات في القطاع المالي للحد من مخاطر الاحتيال والأساليب المستحدثة فيه.

نفيدكم باعتماد دليل المتطلبات الأساسية لمكافحة الاحتيال المالي (Counter-Fraud Fundamental Requirements) والذي يهدف إلى تعزيز ممارسات مكافحة الاحتيال وذلك من خلال تطبيق مجموعة من الضوابط الرقابية لتعزيز ورفع مستوى النضج للتعامل مع المخاطر والأنماط والأساليب المتطورة للاحتيال بشكل استباقي.

عليه، يتعين على شركات التمويل وشركات خدمات المدفوعات الالتزام بما ورد فيه وفق الإجراءات التالية:

أولاً: على المؤسسة المالية إجراء تقييم شامل ودقيق للوضع الراهن لإجراءات مكافحة الاحتيال مقارنةً بما ورد في دليل المتطلبات الأساسية لمكافحة الاحتيال المالي (Gap Assessment)؛ لتحديد مواطن الضعف وتقييم المستوى الحالي للمؤسسة المالية.

ثانياً: على المؤسسة المالية وضع خطة عمل (Roadmap)؛ لتحقيق الالتزام بجميع المتطلبات الواردة في الدليل بعد تقييم الوضع الحالي في بيئة المؤسسة المالية بشكل دقيق واستيفاء موافقة مجلس إدارة المؤسسة المالية على الخطة المعدة (Roadmap) والدعم اللازم لإنفاذها أخذاً بعين الاعتبار الفقرة (خامساً).

ثالثاً: على المؤسسة المالية إرسال التقييم الشامل وخطة العمل المعتمدة إلى البنك المركزي في موعد أقصاه نهاية شهر يوليو ٢٠٢٥م.

رابعاً: على المؤسسة المالية تزويد البنك المركزي بتقارير ربع سنوية عن حالة الالتزام بالدليل اعتباراً من نهاية الربع الثالث ٢٠٢٥م وحتى تحقيق الالتزام الكامل بالمتطلبات.

خامساً: على المؤسسة المالية الالتزام التام بدليل المتطلبات الأساسية لمكافحة الاحتيال المالي في موعد أقصاه ١٣ أبريل ٢٠٢٦م.

سادساً: على المؤسسة المالية إعداد تقرير مفصل من إدارة المراجعة الداخلية – ولها الاستعانة ببيوت الخبرة- يوضح حالة الالتزام بدليل المتطلبات الأساسية لمكافحة الاحتيال المالي بنهاية الربع الثاني ٢٠٢٦ م.

سابعاً: تزويد البنك المركزي بالمتطلبات المذكورة أعلاه إلى البريد الإلكتروني: (DAFS@SAMA.GOV.SA).

ثامناً: يحل دليل المتطلبات الأساسية لمكافحة الاحتيال المالي المرافق محل قواعد مكافحة الاحتيال في شركات التمويل الصادرة بموجب تعميم البنك المركزي رقم (٣٨١٠٠١٠٣٢٤٦) وتاريخ ١٩/١٠/١٤٣٨ هـ، وذلك بدءاً من ١٣ أبريل ٢٠٢٦ م.

ونود الإحاطة أن البنك المركزي سيقوم بعمل زيارات تفتيشية بشكل دوري للتحقق من دقة التقييم ودرجة الالتزام مع دليل المتطلبات الأساسية لمكافحة الاحتيال المالي.

للإحاطة، والعمل بموجبه اعتباراً من تاريخه.

وتقبلوا تحياتي،

يوسف بن أحمد آل الشيخ
وكيل المحافظ للرقابة

نطاق التوزيع:

- شركات التمويل العاملة بالمملكة.
- شركات خدمات المدفوعات العاملة بالمملكة.

Counter-Fraud Fundamental Requirements

April 2025

Version 1.0



Contents

1	Introduction	3
1.1	Objective	3
1.2	Definition of Fraud	4
1.3	Applicability.....	4
1.4	Responsibilities and Interpretation.....	4
1.5	Target Audience	4
1.6	Review, Updates and Maintenance	5
1.7	Reading Guide	5
2	Fundamental Requirements Structure and Features.....	6
2.1	Structure.....	6
2.2	Risk Based Approach	7
2.3	Member Organization Self-Assessment and SAMA Audit	7
3	Control Requirements	8
3.1	Counter-Fraud Governance and Risk Management	8
3.2	Fraud Prevention.....	9
3.3	Fraud Detection.....	11
3.4	Fraud Response	11
3.5	Counter-Fraud Technology	12
4	Control Requirements – Products and Services of Elevated Risk	13
4.1	Counter-Fraud Solutions and Controls for Elevated Risk.....	13
	Appendices.....	15
	Appendix A – Glossary.....	15
	Appendix B – Overview of previous issued SAMA circulars.....	18
	Appendix C – Supervisor Notification form.....	18

1 Introduction

The rapid transformation of the financial services sector has fundamentally altered how consumers manage their money, with digital channels offering instant access to financial products and services from anywhere in the world. This development has substantially increased the speed, volume and value of financial transactions and digital operation of financial services has become critically important to all public and private organizations. Established market operators have evolved to the benefit of consumers and the economy as a whole, while at the same time new players have emerged in the sector using technology solutions to drive further innovation.

This transformation has led to a significant increase in the risk and impact of financial fraud both globally and within the Kingdom of Saudi Arabia ("KSA"). Customers are exposed to ever more sophisticated threats and vulnerabilities can result in rapid exfiltration of funds that are not able to be recovered. In particular, new products and services developed by organizations known as FinTechs have brought welcome competition and digital innovation to the financial sector and deliver significant benefits to consumers and financial institutions. However, if firms in the sector do not implement sufficiently robust controls to safeguard assets and mitigate the risk of customers being exploited by fraud or scams, they can present an unacceptable risk of harm to their customers and to the integrity of the Saudi financial system.

Delivering an effective approach to fraud risk management across the financial sector will help the KSA achieve the 2030 Vision aim to build a stable, thriving, and diversified business environment while protecting members of society and making the Kingdom an unattractive place for fraudsters.

The Saudi Central Bank ("SAMA") developed the Counter Fraud Fundamental Requirements ("Fundamental Requirements") to provide a baseline of minimum standards to apply to Member Organizations regulated by SAMA that are not in scope of the existing Counter-Fraud Framework.

1.1 Objective

Due to the large variation in length of establishment; scale of operations and fraud risk profile of products offered; the objective of the Fundamental Requirements is to help Member Organizations in:

- Establishing a Counter-Fraud Programme that is risk-based and proportionate;
- Managing and mitigating fraud risks in an ever-changing environment;
- Focusing resources on a minimum set of controls aimed at effective prevention of fraud and protection of customers and organizations.

To achieve this objective, the fundamental requirements provide:

- A prioritised set of fraud risk management control requirements;
- A structure and a content that are aligned with other SAMA regulatory frameworks, such as the Counter-Fraud Framework ("CFF") and should be implemented in conjunction with the applicable SAMA Cyber Security requirements which outline controls aimed at an effective protection of information assets and digital services.

1.2 Definition of Fraud

Fraud is defined as any intentional act that aims to obtain an unlawful benefit or cause loss to another party. This can be caused by exploiting technical or documentary means, relationships or social means, using functional powers, or deliberately neglecting or exploiting weaknesses in systems or standards, directly or indirectly.

1.3 Applicability

The Fundamental Requirements are applicable to Member Organizations based on SAMA discretion. Member Organisations required to implement and comply with the Fundamental Requirements will be notified by SAMA.

Due to the elevated fraud risk of products and services offered, Member Organizations (including FinTechs) operating in the payments sector, offering credit cards, electronic money or providing products which can be used to send or receive funds must adopt additional controls to protect their customers against the risk of fraud and to ensure that the organization is not being used to receive the proceeds of fraud. An additional domain mandatory for Electronic Money Institutions (EMIs); Account Information Service Providers (AISPs) and Member Organizations offering digital payment services that offer the means to send and receive funds; Credit Cards; Microfinance; Buy Now Pay Later (BNPL) Services; or safeguarding funds on behalf of customers is included in Chapter 4.

Member Organizations not included in the mandatory list above should take a risk-based approach to the implementation of the additional requirements. Through a risk assessment, Member Organizations should identify, assess, and understand the fraud risk to which they and their customers are exposed, and implement appropriate requirements. The application of a risk based approach will help to encourage growth in the sector by not putting barriers to market entry and allow Member Organizations to implement enhanced measures where the fraud risks are higher and focus resources accordingly.

1.4 Responsibilities and Interpretation

The Fundamental Requirements are mandated by SAMA and will be circulated to Member Organizations for implementation. SAMA, as the owner of the Fundamental Requirements, is solely responsible for providing interpretations of the control requirements, if required. In scope Member Organizations are responsible for implementing and complying with the Fundamental Requirements.

1.5 Target Audience

The Fundamental Requirements are intended for Senior and Executive Management, business owners, members of the Member Organization's Counter-Fraud Department (where applicable) and those who are responsible for, and involved in planning, defining, implementing, and reviewing Counter-Fraud controls across the three lines of defence.

1.6 Review, Updates and Maintenance

SAMA will review the Fundamental Requirements periodically to evaluate its applicability to the context of the KSA financial sector and its intended Member Organizations. If deemed necessary, SAMA will update the fundamental Requirements based on the outcome of the review.

SAMA will implement version control for maintaining the Fundamental Requirements. Whenever making any changes, SAMA will retire the preceding version, as well as release and communicate the new version to all Member Organizations. For the convenience of the Member Organizations, SAMA will clearly indicate any changes to the revised Fundamental Requirements.

1.7 Reading Guide

The Fundamental Requirements is structured as follows:

- Chapter 2 elaborates on the structure of the Fundamental Requirements and provides guidance on how to apply the Fundamental Requirements;
- Chapter 3 presents the Counter-Fraud domains including control requirements;
- Chapter 4 presents control requirements mandatory for EMIs; AISP; and Member Organizations offering digital payment services that offer the means to send and receive funds; Credit Cards; Microfinance; Buy Now Pay Later (BNPL) Services; or safeguarding funds on behalf of customers and applicable to other Member Organizations on a risk based approach as outlined in section 1.3.

2 Fundamental Requirements Structure and Features

2.1 Structure

The Fundamental Requirements span the prevention, detection, and response to fraud, as well as the governance of a Member Organization's Counter-Fraud Programme. Chapter 3 of the Fundamental Requirements is structured around five domains, including:

- Counter-Fraud Governance and Risk Management
- Fraud Prevention
- Fraud Detection
- Fraud Response
- Counter-Fraud Technology

Control requirements have been uniquely numbered throughout the Fundamental Requirements. The control requirements are numbered according to the following numbering system:

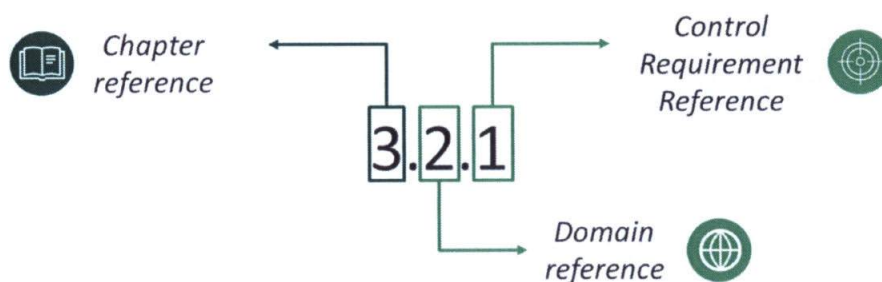


Figure 1. Control requirement numbering system

The figure below illustrates the overall structure of the Fundamental Requirements and indicates the Counter-Fraud domains:

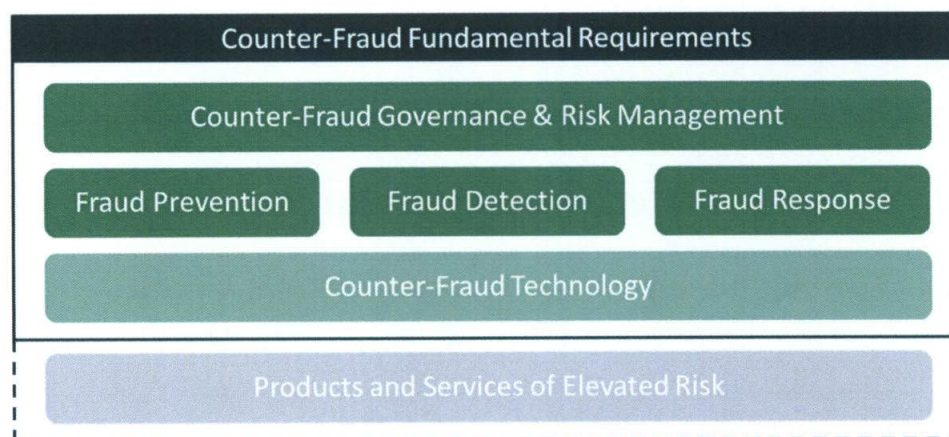


Figure 2. Fundamental Requirements domains

2.2 Risk Based Approach

The domains and control requirements included in the Fundamental Requirements are risk-based and intended to provide Member Organizations with essential direction on how to develop a control structure to mitigate the most common risks they face, without placing undue burden on them that could stifle innovation and business growth.

From this perspective, the Fundamental Requirements set the essential Counter-Fraud minimum standards for Member Organizations that are within the scope of applicability. In addition, SAMA expects Member Organizations to conduct their own internal risk assessments:

- to monitor the development of the fraud threat landscape;
- to identify new and evolving risks particularly as new products and models such as open finance are launched;
- to evaluate the potential impact of these risks; and
- where deemed necessary to implement additional or enhanced control requirements beyond the fundamental requirements to mitigate these risks in line with the entities risk appetite.

2.3 Member Organization Self-Assessment and SAMA Audit

The implementation of the fundamental requirements at the Member Organizations will be subject to periodic self-assessment. The self-assessment will be performed by the Member Organizations based on a questionnaire. The Member Organizations will send a copy of its self-assessment to SAMA, and SAMA reserves the right to review the self-assessment to evaluate compliance with the fundamental requirements at its discretion. SAMA also reserves the right to audit the compliance with the fundamental requirements of Member Organizations at any time.

3 Control Requirements

3.1 Counter-Fraud Governance and Risk Management

Control ID	Control requirement description
3.1.1	Member Organizations should develop a risk-based Counter-Fraud Programme proportional to the size and nature of its business to address people, process, and technology, including adequate systems and controls to prevent, detect and respond to fraud. The progress of the implementation, performance and compliance of the Counter-Fraud systems and controls should be periodically monitored using Key Performance Indicators (KPIs) with updates made to the programme to address new and emerging threats and changes in the severity of existing risks.
3.1.2	Member Organization's Board of Directors should be ultimately responsible for the establishment of a robust governance structure that is supported by adequate resources of appropriate role and seniority to set the tone from top; and provide leadership, direction and oversight of the overall approach to fraud risk management.
3.1.3	Member Organizations should establish and maintain a Counter-Fraud Governance Committee (CFG) that is required to meet at least on a quarterly basis. The CFG should at a minimum be responsible for approving, supporting, communicating, and monitoring the Counter-Fraud Program; Counter-Fraud Policy; and Management Information.
3.1.4	Member Organizations should consider areas of operational collaboration between Counter-Fraud, Cyber Security and Financial Crime Teams. Examples of capabilities to consider include establishment of multi-disciplinary contacts; cross training; development of joint task forces; sharing threat intelligence; aligning incident response; and coordinating corrective actions.
3.1.5	Member Organizations should define, approve, communicate and implement Counter-Fraud Policies, Standards and Procedures aligned to the risks identified in the Fraud Risk Assessment and the legal, regulatory and payment operator requirements of the Member Organization. Counter-Fraud Policy should include at a minimum, overall Counter-Fraud objectives and scope; policy requirements; consequences of non-compliance; and roles and responsibilities, including overall responsibility for Counter-Fraud.
3.1.6	Member Organizations should periodically review and update Counter-Fraud Policy and Procedures to ensure they take into consideration fraud and attempted fraud impacting the Member Organization and the sector; the evolving fraud landscape; the fraud risks and scale of the Member Organization's business model and operations; and manage identified risks effectively.
3.1.7	Member Organizations should identify and implement reporting of appropriate Management Information to adequately inform Senior Management of Counter-Fraud risks and performance. At a minimum, this should include volume and trends of fraud cases handled; near misses or potential frauds that were detected and prevented; typologies; and the value of both customer and operational fraud losses.
3.1.8	Member Organizations should notify the SAMA Executive Department of Operational Resilience Control (ORC) immediately of: - A new fraud typology (e.g., type of fraud not previously observed or new scam attempt detected). - Any significant internal or external fraud incidents. When assessing whether a fraud is considered significant, Member Organizations should consider the value of the loss to the organization or its customers; the number of customers impacted; reputational damage to the organization or wider sector; regulatory breaches; and the potential to impact other Member Organizations. Member Organizations should use the standard reporting template in Appendix B to notify SAMA.
3.1.9	Member Organizations should define Fraud Risk Appetite to state the level of fraud risk the Member Organization is willing to tolerate when designing and implementing Counter-Fraud systems and controls.

3.1.10	Member Organizations should define, approve, and monitor Key Risk Indicators (KRIs) to measure and evaluate their position against agreed Fraud Risk Appetite and the control requirements in this document.
3.1.11	Member Organizations should conduct Intelligence Monitoring utilising internal and external information sources to develop and maintain an awareness of new and emerging fraud threats which may impact the organization and its customers.
3.1.12	Member Organizations should conduct an enterprise-wide Fraud Risk Assessment to identify fraud risks to which they or their customers are subject; inform the controls required based on the level of inherent fraud risk identified for products and services offered; assess the effectiveness of controls in place to mitigate the risks; and determine residual risk. The risk assessment should be refreshed periodically and updated following changes in the internal or external fraud risk environment, e.g., new products or services; new digital platforms; new business acquisitions; new fraud threats identified.
3.1.13	Prior to the introduction of a new product or service, Member Organizations should engage Counter-Fraud to assess the potential fraud vulnerabilities and recommend controls required to mitigate the risks.
3.1.14	Where third party services or resources (e.g., contractors or Managed Services) are used to fulfil Counter-Fraud responsibilities, Member Organizations should ensure the resource is appropriately vetted and monitored.
3.1.15	Member Organizations should ensure periodic independent audits are conducted in accordance with generally accepted auditing standards and relevant SAMA regulations to verify that the fraud control design is adequately implemented and operating as intended.

3.2 Fraud Prevention

Control ID	Control requirement description
3.2.1	Member Organizations should define, communicate and implement Due Diligence standards aligned to the risks identified in the fraud risk assessment for employees, customers and third parties.
3.2.2	Employee Due Diligence measures should reflect the risks of internal fraud impacting the Member Organization and have the objective of establishing the identity, integrity, and verifying the credentials of the employee, enabling the Member Organization to determine whether they are suitable for the position (e.g., Confirmation of identity, Criminal background, and Previous employment checks).
3.2.3	When establishing a new customer relationship, Member Organizations should check and verify the identity of the customer to reasonably ensure that it is not exposed to external fraud risk.
3.2.4	Third Party Due Diligence should consist of checks and vetting procedures on a risk-based approach to allow an assessment of the fraud risks presented by the relationship and ensure third parties are appropriately managed to mitigate the risk.
3.2.5	Member Organizations should periodically conduct Counter-Fraud training to ensure all employees are aware of their responsibilities under applicable Counter-Fraud Policies, Standards and Procedures; promote awareness of fraud risks; create a positive Counter-Fraud culture; and communicate the requirement to report any suspicions of fraud in a timely manner.
3.2.6	Customer fraud awareness activity should deliver relevant and timely education to customers and promote awareness of fraud risks, e.g., information on recent fraud cases, current or emerging threats, how customers can protect themselves and how to report fraud.
3.2.7	Member Organizations should define, approve, implement and maintain an authentication standard that is aligned to Cyber Security control requirements. The standard should consider both customer access to products and services; and employee and third party access to Member Organization systems.

3.2.8	Member Organizations should adopt a risk-based approach to authentication with higher risk access, instructions or activity (e.g., registration process for online or mobile product access; payments; reset of security credentials; or instructions for disbursement of a loan) subject to multi-factor authentication before they are acted upon.
3.2.9	Member Organizations should define, approve, implement and maintain controls to mitigate the risk of internal fraud occurring, e.g., Requiring employees to adhere to a Code of Conduct; segregation of duties; secondary checking of control operation; restricting access to sensitive and customer information; controls over access to cash or cheques; and physical security of assets.
3.2.10	Member Organizations should put in place appropriate processes and controls to deter and avoid conflicts of interest and related party transactions for their directors, managers, employees, external businesses, and contractors, e.g., information barriers to limit the flow of information; training on what constitutes a conflict of interest and how to avoid; and clear guidance on prohibited activity.
3.2.11	Member Organizations should define, approve, implement and maintain controls to mitigate the risk of external fraud occurring, e.g., Communication channels to report fraud; customer identity and access management controls; issue of OTPs to verify payments or activity; blocking or freezing accounts if fraud is suspected; and additional verification checks to verify unusual behaviours or requests.
3.2.12	To encourage fraud conscious behaviours in customers, Member Organizations should educate customers on the channels they will use to communicate with them and not include clickable links in emails and SMS sent to customers.

3.3 Fraud Detection

Control ID	Control requirement description
3.3.1	Member Organizations should design and implement controls to monitor customer products and services for behaviours and activity that may be indicative of external fraud. At a minimum these should address the risk presented by: - First party fraud – Where a customer of the Member Organization misrepresents their identity, gives false information to commit fraud using their own account, loan application or submits false or inflated insurance claims. - Second party fraud – Where a customer or individual knowingly provides their personal information or allows their identity to be used to commit fraud. - Third party fraud – Where an unauthorised individual or entity obtains details of a customer of a Member Organization without his/her consent or knowledge, then uses the information to commit fraud.
3.3.2	Member Organizations should design and implement controls to monitor employees in roles which have been identified in the Fraud Risk Assessment as presenting a risk of internal fraud, e.g., Audit trail of system access and activity; monitoring for unusual behaviours or activity; reconciliation and settlement of financial transactions; monitoring and approval of corporate card use and expense claims.
3.3.3	Member Organizations should define, approve, implement and maintain a whistle blowing process across multiple channels for employees, customers and third parties to report potential fraud violations, the process should comply with SAMA relevant regulations for Financial Institutions.

3.4 Fraud Response

Control ID	Control requirement description
3.4.1	Member Organizations should define, approve, implement and maintain a Fraud Response Plan which outlines the organizational response to an actual or suspected fraud incident. Where appropriate this should be aligned with the enterprise incident management process. The response plan should include: - Roles and responsibilities for individuals and teams required to respond to a potential fraud. - Procedures to quickly respond to potential fraud cases identified by the Member Organization, informed by the customer or notified by other organizations. - The actions the Member Organization will take when fraud is suspected or has been identified. - The process to be followed in the event a potential fraud incident is detected outside of the normal working hours of the Member Organization. - Determining external notifications required (e.g., liaising with law enforcement, notifying credit information companies, reporting to SAMA, reporting to the General Directorate of Financial Intelligence (FIU) if the Member Organization has any suspicion that rises to the level stated in article 15 of AML Law and article 17 of CTF law).
3.4.2	Member Organizations should conduct a prompt and competent assessment, investigation, and resolution of all suspected or identified fraud. If the required capabilities to conduct the investigation are not available internally, the Member Organization should seek external support to investigate and resolve the fraud as required, and ensure that the external support resource is appropriately vetted and monitored.

3.4.3	Member Organizations should implement and maintain a system or database to manage the responses to fraud and be used as a repository for fraud case data retention in-line with legal and regulatory requirements. This should be used to record and monitor suspected fraud alerts, internal and external reports, case investigations from initial assessment to resolution, and actions taken.
3.4.4	Member Organizations should define, approve, implement and maintain a process to identify the root cause of a fraud incident at the conclusion of an investigation, e.g., Understand point of compromise; Determine involvement of other parties; Review control failures.
3.4.5	Following determination of the root cause, Member Organizations should define, approve and implement a process to determine lessons learnt and inform corrective actions to prevent a recurrence, e.g., Collating and storing data which may support the analysis of patterns in fraud cases; assessing whether there is a gap in the current control framework; evaluating whether the issue could impact other Member Organizations; and sharing relevant information where permitted.
3.4.6	Member Organizations should take corrective actions to remediate the root cause and/or the impact of a fraud incident, e.g., Implementing a new control; providing employee training; putting a fraud victim back into the position they were in prior to the incident or remediating a credit report; providing support to a victim of fraud; exiting a customer or third party relationship if they are found to be the perpetrator of a fraud; internal disciplinary action where internal fraud is identified; and liaising with law enforcement agencies.

3.5 Counter-Fraud Technology

Control ID	Control requirement description
3.5.1	Based on the output of the fraud risk assessment, the scale of the organization and the nature of the products offered, Member Organizations should implement detection solutions to monitor customer products and services, and internal systems and accounts for transactions or behaviours that may be indicative of fraud.
3.5.2	Where fraud detection solutions are in use, Member Organizations should develop a holistic 360 degrees view of current sources of data to be used to inform detection and prevention of suspicious activity and fraud, e.g., Customer products and services held; Contact channels; External information; Transactional data; Non-transactional data.
3.5.3	Where fraud detection solutions are in use, Member Organizations should implement controls (e.g., data governance, de-duplication, data quality alerts, regular audit, integration testing, regression testing for change management) to ensure that the underlying data is timely, complete and accurate.
3.5.4	To optimise fraud detection solutions, Member Organizations should monitor performance and periodically test effectiveness through tuning and calibration.
3.5.5	Member Organizations should periodically review scenarios and parameters in fraud detection solutions to ensure they remain appropriate in view of the insights gathered in Intelligence Monitoring and/or the outcome of the Fraud Risk Assessment.

4 Control Requirements – Products and Services of Elevated Risk

The following additional requirements are mandatory for licensed EMIs; AISPs; and Member Organizations offering digital payment services that offer the means to send and receive funds; Credit Cards; Microfinance; Buy Now Pay Later (BNPL) Services; or safeguarding funds on behalf of customers.

In addition, as outlined in section 1.3, Member Organizations not included in the mandatory list above should take a risk-based approach to the implementation of the additional requirements and determine and document the most effective way to mitigate the fraud risks they have identified.

4.1 Counter-Fraud Solutions and Controls for Elevated Risk

Control ID	Control requirement description
4.1.1	Member Organizations should implement real-time fraud detection and prevention solutions to identify anomalies in transactional and non-transactional data, and monitor systems and internal accounts for transactions or behaviours that may be indicative of fraud.
4.1.2	Fraud detection systems should operate 24/7 with appropriate resources in place to manage outputs on a timely basis.
4.1.3	Member Organizations should ensure that the solutions and rules are designed or can be customised to align to the products, services, and fraud risks of the organization.
4.1.4	Member Organizations should implement controls that allow real-time actions such as freezing of accounts and blocking of transactions in a timely manner if a customer or Member Organization suspects an account has been compromised.
4.1.5	Member Organizations should use data and intelligence to screen and block transactions or access from identified high risk accounts; GPS locations; IP addresses; email addresses; devices that are subject to jailbreaking or rooting; use of VPN services when accessing online or mobile services; and compromised devices or those that have previously been used for fraud.
4.1.6	Member Organizations should implement device registration controls which allow users to register trusted devices for access management.
4.1.7	Member Organizations should implement controls to protect customers from payments and product application fraud, including but not limited to: a. Notification to the customer of new payees added (e.g., SMS, Mobile App notification). b. Notification to the customer when: a. User submitted the product application request. b. When the product request is approved or denied. c. Setting a default limit subject to periodic review for single and daily transactions.
4.1.8	Member Organizations should conduct multi-factor authentication checks to verify: a. Payments to newly added payees or beneficiaries b. Unusual transactions (e.g., transactions after a period of account dormancy, changes to customer behaviours, payments to a high-risk foreign jurisdiction). c. Unusual patterns of transactions (e.g., multiple payments to one or more beneficiaries in a short period, rapid inflow and outflow of funds). d. Transactions exceeding a defined value threshold. e. Requests to increase the single or daily transaction limit. f. Initial transactions after registration for online or mobile services, or registration of a new device.

4.1.9	Multi-factor authentication conducted by Member Organizations for identification and transaction verification should not solely consist of One Time Passwords (OTPs) sent via SMS. Member Organizations should implement additional factors, e.g., - Approval of transactions through Mobile App by a push notification on a trusted device; - Device characteristics; Precise Geolocation; Behavioural profile; or Biometric behaviours; - Call-backs.
4.1.10	Where a Member Organization sends an OTP via SMS, the purpose, amount and merchant name should be clearly defined and in line with SAMA approved notification templates. OTPs sent via SMS should be in the language selected by the customer on the account (e.g., Arabic, English).
4.1.11	Member Organizations should implement controls to detect mule accounts (e.g., accounts set-up to receive fraudulently obtained funds and launder the proceeds of crime) and take action to prevent the outward flow and recovery of funds.
4.1.12	Member Organizations should update controls, rules and decision-making models in solutions to mitigate fraud risks resulting from new and emerging fraud typologies identified through intelligence monitoring or root cause analysis and take proactive action to prevent fraud.
4.1.13	Where a customer relationship is initiated on a remote basis (e.g., online), Member Organizations should assess the risk of impersonation and the set-up of mule accounts, implementing appropriate controls to mitigate the risk, including but not limited to: - Ensuring a phone number and National ID/Iqama is linked to one customer application only. In the event an exception is identified (e.g., dependent family member), additional due diligence checks should be conducted to validate the authenticity of the application and monitoring use cases should be developed. - Verification that the ownership of the phone number is registered to the same user through a trusted party (i.e., the name of the account applicant and national ID match). - Authentication of the account registration request via the National Single Sign-On portal using Biometric based authentication (e.g., facial identification from national trusted party), including a one-time-password mechanism (OTP) explaining that a new account is being registered as a form of verification. The OTP must be sent to the verified phone number as per step (4.1.13-b). - Requiring the use of a registered National Address. - Notification of the completion of account registration should be sent to verified phone number that is registered for the account as well as to the phone number that is registered in the national single sign-on portal. - Following initial set up, account fraud risk scoring should be established with restrictions placed on the account where applicable (e.g., reduced transaction value limit) until such time as the Member Organization validates that the customer is genuine through a combination of activities (e.g., use of biometric authentication mechanism through facial identification from national trusted party periodically, physical presence in a branch, regular pattern of account activity over a period of time). - Member Organization should have process implemented to assure the recipient IBAN belongs to the loan requester. - Implementing a process to ensure the ability to identify the source of inbound customer transactions. - Implementing a process to allow accepting/rejecting inbound customer transactions that are not originating from the same customer for e-wallet card top-up and crowdfunding participation.

Appendices

Appendix A – Glossary

Term	Definition
Access Management	The process of granting authorised users the right to use a service, while preventing access to non-authorised users.
Code of Conduct	A defined set of expectations which outline principles, values, and behaviours that an organization considers important to its operations and success.
Contractor	An individual or organization under contract for the provision of services to an organization.
Counter-Fraud Culture	The shared values, beliefs, knowledge, attitudes and understanding about fraud risk within an organization. In a strong Counter-Fraud culture people proactively identify, discuss, and take responsibility for fraud risks.
Counter-Fraud Governance	A set of responsibilities and practices exercised by the Board, Executive and Senior Management with the goal of providing strategic direction for countering fraud, ensuring that Counter-Fraud objectives are achieved, ascertaining that fraud risks are managed appropriately and verifying that the enterprise's resources are used responsibly.
Counter-Fraud Governance Committee (CFGCC)	A governance Structure owned by Senior Management with responsibility for oversight and control of all aspects of the organisational Counter-Fraud Programme.
Counter-Fraud Policy	A set of criteria for the provision of Counter-Fraud activities. It sets the commitment and objectives for Counter-Fraud and documents responsibilities.
Counter-Fraud Programme	A collection of strategy, policies, processes, guidelines, risk management approaches, actions, training, best practices, assurance, and technologies that are used to protect the Member Organization and its customers against internal and external fraud threats.
Counter-Fraud Department	A dedicated department or team established for the purpose of managing the implementation of the organization's Counter-Fraud objectives.
Cyber Security	Cyber security is defined as the collection of tools, policies, security concepts, security safeguards, guidelines, risk management approaches, actions, training, best practices, assurance, and technologies that can be used to protect the Member Organization's information assets against internal and external threats.
Due Diligence	The investigation of an employee, customer or third party to confirm facts and that it is as presented. Additional guidance on Due Diligence standards can be observed in the SAMA CFF.

Electronic Money	Monetary value represented by a claim on the issuer which is: (a) stored electronically, including magnetically. (b) issued on receipt of funds. (c) used for the purposes of making Payment Transactions. (d) accepted as a means of payment by persons other than the issuer; and (e) is not stored on a "Closed Loop Prepaid Account" or a "Restricted Loop Account".
Electronic Money Institution (EMI)	A Payment Service Provider that is licensed to issue Electronic Money
Employee	Employees encompass members of the Board of Directors and its committees, Executives, permanent and contract employees, consultants, and employees working through a third party
External Fraud	A fraudulent event conducted by any persons on the 'outside' of the organization i.e., not employed by the organization.
Fraud	Any intentional act that aims to obtain an unlawful benefit or cause loss to another party. This can be caused by exploiting technical or documentary means, relationships or social means, using functional powers, or deliberately neglecting or exploiting weaknesses in systems or standards, directly or indirectly.
Fraud case	An individual occurrence of fraud recognised by an organization.
Fraud Landscape/Threat Landscape	Fraud threats, trends, and developments in the political, economic, social, technological, or legal environment.
Fraud Response Plan	A plan which details the actions to be undertaken when a fraud is suspected or has been detected. This will include reporting protocols, team responsibilities and information logging.
Fraud Risk Appetite	The level of fraud risk that an organization is willing to accept or tolerate in pursuit of its objectives.
Fraud Risk Assessment	A process aimed at addressing the organization's vulnerability to fraud. This will include identification of fraud risks, assessment of the likelihood that fraud risks will occur and the resulting impact, determination of the appropriate response, and review of the control framework.
Fraud Risk Management	The ongoing process of identifying, analysing, monitoring, and responding to fraud risks to which the organization and its customers are exposed.
Fraud Threat	Any circumstance or event with the potential to result in a fraud event occurring.
Fraud Typology	A categorisation of a fraud event based on its methodology and common themes with other fraud events.
Incident	A fraud case or series of associated cases.
Inherent Risk	The fraud risks posed to the organization's business operations or its customers if there were no controls present.
Intelligence Monitoring	The process of continually reviewing and gathering intelligence on new and emerging fraud threats and typologies from a comprehensive range of sources. Additional guidance on intelligence monitoring can be observed in the SAMA CFF.
Internal Fraud	Fraud committed by or with the assistance of people employed by the organization.

Key Risk Indicators (KRIs)	A measure used to indicate the probability an activity or organization will exceed its defined risk appetite. KRIs are used by organizations to provide an early signal of increasing risk exposures in various areas of the enterprise.
Management Information	Information collated and then presented, often in the form of a report or statement, to management or decision makers for the purpose of identifying trends, solving issues and/or forecasting the future.
Member Organization	Financial institutions or financial services providers regulated by SAMA.
Mule accounts	Accounts set-up (often via remote or online channels) to receive fraudulently obtained funds and launder the proceeds of crime.
Multi-Factor Authentication	Authentication using two or more factors to achieve authentication. Factors include something you know (e.g., password/PIN), something you have (e.g., cryptographic identification device, token), or something you are (e.g., biometric).
Near miss	Potential fraud incidents that are detected and remediated prior to the fraud incident resulting in a monetary loss.
One Time Password (OTP)	An automatically generated string of characters or numbers sent to a known device to be used for one single login attempt / transaction approval.
Residual Risk	The remaining risk after management has implemented a risk response.
Risk	A measure of the extent to which an organization is threatened by a potential circumstance or event, and typically a function of: (i) the adverse impacts that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence.
Rules	Rules used in fraud prevention and detection systems use correlation, statistics, and logical comparison of data to identify a pattern based on insights gained from previous known fraud incidents.
Scams	Where an individual is tricked into making or authorising a payment to a criminal's account. Scammers typically use social engineering and can impersonate banks, investment opportunities, utility companies and government bodies using emails, phone calls and SMS that appear genuine.
Senior Management	The highest level of management in an organization (the level below the Board) and their direct reports.
Third Party	A separate unrelated entity that provides an organization with a service. This may include suppliers, technology providers (e.g., Absher, Nafath), outsourcers, intermediaries, brokers, introducers, and agents.
Trusted Device	A trusted device is a device that the customer owns, controls access to, and uses often.
Violation	Any act, or concealment of acts, of fraud, corruption, collusion, coercion, unlawful conduct, misconduct, financial mismanagement, accounting irregularities, conflict of interest, wrongful conduct, illegal or unethical practices or other violations of any applicable laws and instructions.

Appendix B – Overview of previous issued SAMA circulars

The Fundamental Requirements shall supersede the Anti-Fraud Rules for Finance Companies issued vide SAMA circular no. 381000103246 dated 19/10/1438AH.

Appendix C – Supervisor Notification form

Fraud Supervisory Notification

A submission to the manager of SAMA Executive Department of Operational Resilience Control (ORC).

The Saudi Central Bank (SAMA) requires immediate notification of new fraud typologies and significant fraud incidents to mitigate the risk of the fraud impacting additional customers, other organizations, or the financial sector in the KSA. This form should be used to provide the notification. Please note that all required information must be provided, however it is understood that not all information may be available at the time of notification. Where information is not available at the time of notification, any gaps should be supplied to SAMA promptly as the investigation progresses.

Notifier Information

NOTIFIER'S SIGNATURE*	NOTIFIER'S POSITION*	DATE*
NOTIFIER'S NAME*	MEMBER ORGANIZATION OF NOTIFIER*	

FRAUD NOTIFICATION TYPE* ☐ New typology ☐ Significant external fraud ☐ Significant internal fraud ☐ Significant accounting irregularity	DATE OF INCIDENT*
ORIGIN OF THE INCIDENT*:	
METHODS USED*:	
RELATED PARTIES (INTERNAL AND EXTERNAL)*:	

OUTCOME (INCLUDING LOSSES WHERE APPLICABLE)*:
CORRECTIVE ACTIONS*:
ADDITIONAL INFORMATION:

* Denotes required fields